By TOUCH DEN · November 11, 2026

Threats, Vulnerabilities, and Risk



Video 1 · The Three Words, and Where Weakness Comes From

Security Fundamentals · Section 3

In this video, you will learn:

- The precise difference between a threat, a vulnerability, and a risk
- Where vulnerabilities come from
- Threat sources and threat events

The three words, precisely

Using these words precisely is the mark of someone who understands security.

- ***Threat:*** *something bad that could happen, or an actor who could cause it. A ransomware group.*
- ***Vulnerability:*** *a weakness a threat can use. Staff open attachments without checking.*
- ***Risk:*** *the chance the two meet, and how bad it would be. A ransomware outbreak that stops the business for days.*

*Each word points to a **different fix**: you rarely remove the threat, but you can remove the **vulnerability** and reduce the **risk**.*

Where vulnerabilities come from

Most are ordinary gaps, not exotic hacking tricks.

Source	*Example*
Software bug	*A flaw that lets an attacker run commands*
Misconfiguration	*A database open to the internet, no password*
Weak design	*A system that trusts whatever the app says*
People	*Phishing; reused passwords; a propped-open door*
Process	*Nobody applies updates or reviews access*
Physical	*An unlocked server room*
Third parties	*A bug in a library or supplier you rely on*

*Published software weaknesses get a public ID: a **CVE**.*

Not every threat is a hacker

*Split a threat into the **source** (who/what) and the **event** (what happens).*

Threat source	*Example*
Adversarial	*A criminal group, a lone attacker, a nation-state*
Accidental	*A user deletes the wrong file*
Structural	*A disk or server fails*
Environmental	*Fire, flood, power loss*

A flood that destroys your only server breaks availability just like an attacker. Good risk work includes both.

Recap: the three words

- **Threat** = the bad event/actor; **vulnerability** = the weakness; **risk** = likelihood × impact of the two meeting.
- Each points to a different fix; you remove vulnerabilities and reduce risk.
- Threats are not only attackers: accidents, failures, and nature count too.

Next video: how we measure risk.

Threats, Vulnerabilities, and Risk



Video 2 · Measuring Risk

Security Fundamentals · Section 3

In this video, you will learn:

- Likelihood and impact, kept apart
- Qualitative rating (Low–Med–High)
- Quantitative rating (money: SLE, ARO, ALE)

Likelihood and impact

Every risk has two dimensions, and they call for different responses.

- ***Likelihood:*** *how probable is it to happen and succeed?*
- ***Impact:*** *if it happens, how bad, in money, downtime, harm, legal trouble, reputation?*

Risk = likelihood × impact.

- *High likelihood, low impact → fix cheaply or accept.*
- *Low likelihood, high impact → insurance, off-site backups.*
- ***High likelihood, high impact → fix first.***

Qualitative rating

Simple bands, placed on a grid. Quick, needs no exact data, good for most small organizations.

	Low impact	**Med impact**	**High impact**
High likelihood	Medium	High	High
Med likelihood	Low	Medium	High
Low likelihood	Low	Low	Medium

*Deal with the **High** cells first. Weakness: "High" is a judgement, and people may disagree.*

Quantitative rating (money)

Estimate the yearly cost of a risk:

- ***SLE** (Single Loss Expectancy): cost of one occurrence. Stolen laptop: $1,500.*
- ***ARO** (Annualized Rate of Occurrence): times per year. 2 per year.*
- ***ALE = SLE × ARO**. $1,500 × 2 = $3,000 per year.*

Now you can compare: a $1,000/year control that halves the loss saves $1,500 for $1,000, so it is worth it.

The numbers are estimates: don't mistake precision for certainty.

Recap: measuring risk

- *Keep **likelihood** and **impact** apart; risk = the two multiplied.*
- ***Qualitative** (Low–Med–High) sorts quickly; **quantitative** (SLE × ARO = ALE) guides big money decisions.*
- *Most real work mixes both.*

***Next video:** once you've ranked a risk, what do you do about it?*

By TOUCH DEN · November 11, 2026

Threats, Vulnerabilities, and Risk



Video 3 · Treating Risk

Security Fundamentals · Section 3

In this video, you will learn:

- The four ways to treat a risk
- Residual risk
- Writing a simple risk register

The four ways to treat a risk

Treatment	Meaning	Example
Reduce	Add controls to lower likelihood or impact	Train staff; filter email
Transfer	Make it someone else's cost	Cyber-insurance
Avoid	Stop doing the risky thing	Let a provider store card numbers
Accept	Live with a small risk	Accept a rare mistyped order

Accepting is a real choice, but it must be a decision by someone with authority, not ignoring the risk.

Treatments often combine.

Residual risk

What is left after your controls is residual risk. *No treatment removes a risk completely.*

- *Phishing is High. Add training, an email filter, and MFA.*
- *Likelihood drops a lot, but not to zero: someone may still click.*
- *That remaining chance is the residual risk.*

Leaders then decide, explicitly, whether the residual risk is acceptable. This is why security is ***never "finished"****.*

A simple risk register

A one-page table, kept current, puts a small business ahead of most.

Risk	Rating	Treatment	Owner
Ransomware via phishing	High	Training, filter, offline backups	Manager
Laptop lost/stolen	Medium	Encryption; insurance	IT
Website down on a busy day	High	Extra capacity, monitoring	IT
Fire in the office	Medium	Insurance; off-site backups	Owner

Each row is a specific decision, owned by a real person.

Recap: treating risk

- Four treatments: **Reduce, Transfer, Avoid, Accept**, often combined.
- **Residual risk** always remains and must be accepted on purpose.
- A **risk register** turns "are we secure?" into a short list of owned decisions.

Next lesson: Who attacks, and why.